

WEB APPLICATION SECURITY ASSESSMENT AND REMEDIATION

Module 6 Assignment — Client Side Attacks

Prepared by: Chandrapal Singh Panwar

Date: 05 October 2026

Target: Local DVWA — <http://127.0.0.1:42001/>

Environment: Authorized educational laboratory

1. Executive Summary

This assessment was conducted against a locally hosted Damn Vulnerable Web Application (DVWA) in a controlled educational laboratory. The objective was to identify and document client-side and related web application security weaknesses, including reflected, stored and DOM-based Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), response/security header weaknesses, brute-force behavior, and exposure of personally identifiable information (PII).

Testing confirmed all three XSS categories in the vulnerable DVWA environment. A CSRF password-change scenario was also demonstrated. Response headers were reviewed and recommended defensive headers were not observed in the tested response. Authentication behavior was assessed manually, and PII exposure was demonstrated through the vulnerable application. Remediation and security-awareness recommendations are included.

2. Scope and Environment

Item	Details
Application	Damn Vulnerable Web Application (DVWA)
Target	http://127.0.0.1:42001/
Testing scope	Local authorized lab only
Security level	Low
Primary tools	Firefox, Burp Suite
Assessment focus	XSS, CSRF, security headers, brute force, PII

3. Methodology

- Reviewed the vulnerable DVWA modules and selected the required client-side/security assessment areas.
- Performed manual validation of reflected, stored and DOM-based XSS.
- Crafted and tested a CSRF password-change scenario in the local lab.
- Inspected HTTP response headers using Burp Suite.
- Tested authentication behavior using invalid and valid lab credentials; prepared a Burp Intruder workflow without claiming an automated brute-force success.
- Reviewed the SQL Injection page for exposed user-related information and documented the PII implications.
- Prepared remediation and security-awareness recommendations.

4. Findings Summary

Finding	Status	Risk	Evidence
Reflected XSS	Confirmed	High	Evidence 1
Stored XSS	Confirmed	High	Evidence 2
DOM-based XSS	Confirmed	High	Evidence 3
CSRF	Confirmed	High	Evidence 4
Security headers	Weak/missing recommended controls observed	Medium	Evidence 5
Brute-force protection	Weak authentication controls observed	Medium	Evidence 6–7
PII exposure	Confirmed	High	Evidence 8

5. XSS Assessment

5.1 Reflected XSS

A reflected XSS payload was supplied through the vulnerable input. The browser displayed the alert generated by the injected JavaScript, confirming that attacker-controlled input was reflected into the response without adequate output encoding.

Impact: A crafted URL/request could cause attacker-controlled JavaScript to execute in a victim's browser under the application's origin.

Remediation: Apply strict server-side input validation and context-aware output encoding; avoid unsafe HTML/JavaScript injection; deploy a restrictive CSP.

Evidence 1 — Reflected XSS

Reflected XSS payload execution in the local DVWA application.

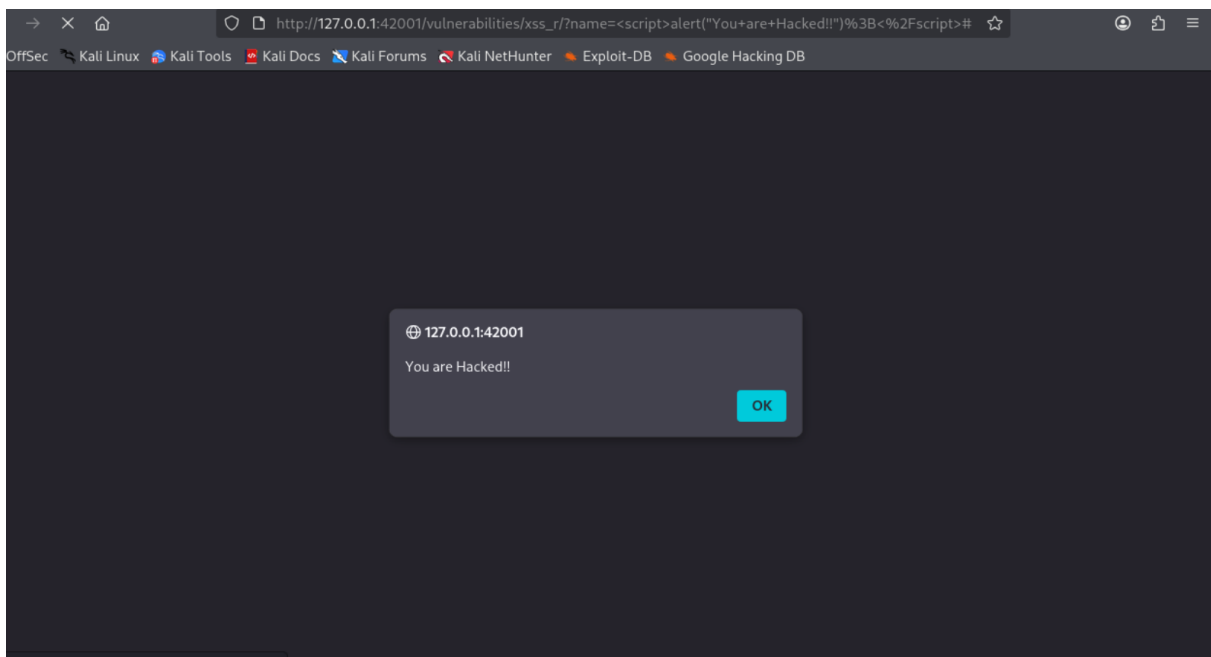


Figure: Evidence 1 — Reflected XSS

5.2 Stored XSS

A malicious script was submitted through the guestbook functionality and subsequently executed when the stored content was rendered. This confirms persistent/stored XSS in the intentionally vulnerable application.

Impact: Malicious content can affect users who later view the compromised page/content and can execute in the application's browser security context.

Remediation: Sanitize content where HTML is permitted, encode output according to context, validate stored input, and avoid unsafe DOM sinks.

Evidence 2 — Stored XSS

Stored XSS payload execution from stored guestbook content.

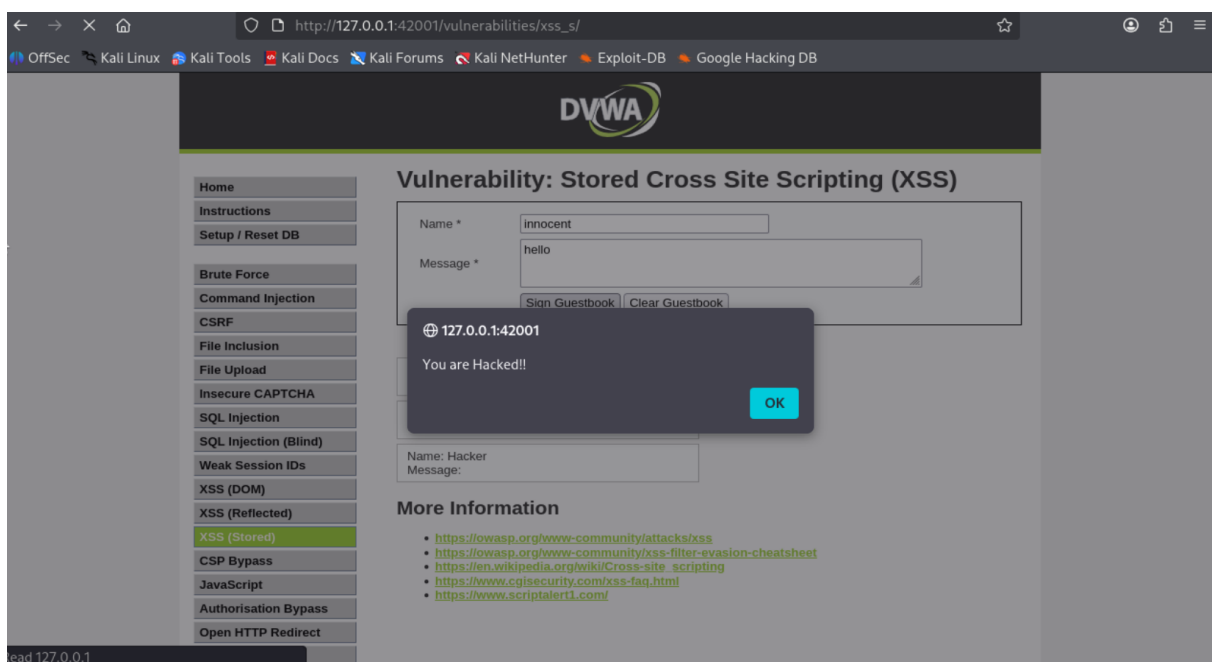


Figure: Evidence 2 — Stored XSS

5.3 DOM-based XSS

Attacker-controlled data supplied through the URL was processed by client-side code and resulted in JavaScript execution. This demonstrates DOM-based XSS, where the vulnerability exists in client-side processing of untrusted data.

Impact: A crafted URL or input can cause client-side script execution in the context of the vulnerable application.

Remediation: Use safe DOM APIs, avoid inserting untrusted data into dangerous HTML/JavaScript sinks, validate input, and deploy a restrictive CSP.

Evidence 3 — DOM-based XSS

DOM-based XSS triggered through attacker-controlled URL input.

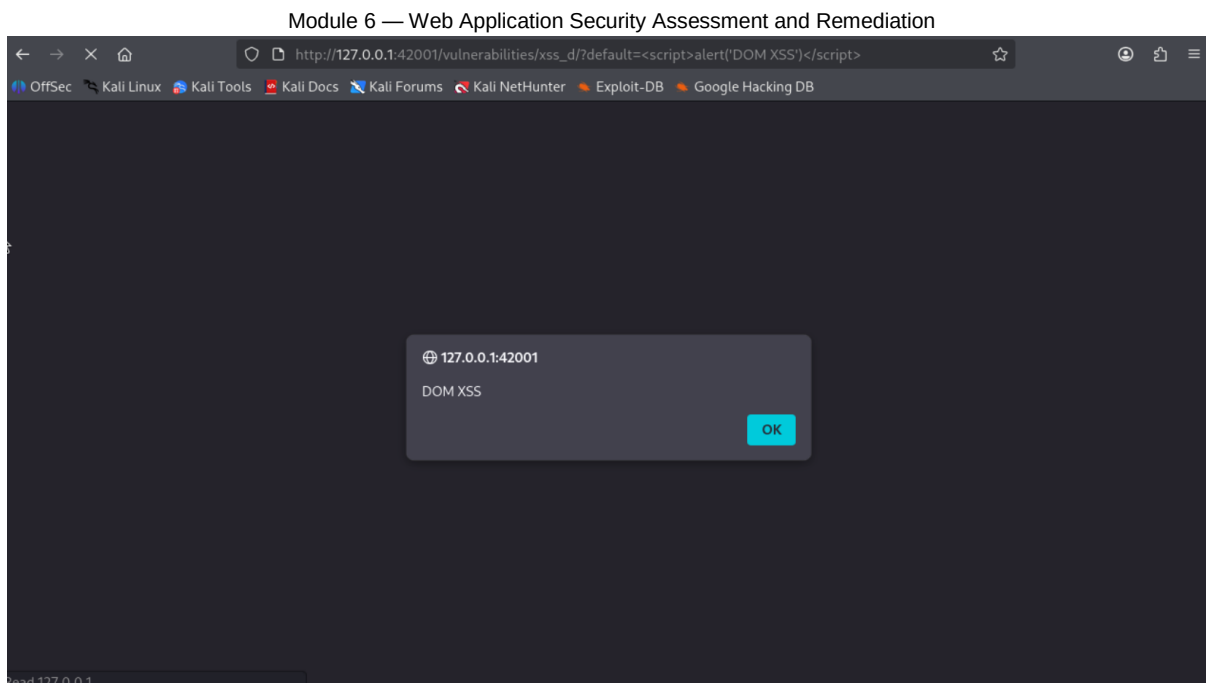


Figure: Evidence 3 — DOM-based XSS

6. CSRF Assessment

A CSRF attack scenario was demonstrated against the DVWA password-change functionality. A crafted request caused the application to return a successful password-change response in the local laboratory.

Impact: If a real application lacks CSRF protection, an attacker may cause an authenticated victim's browser to perform unintended state-changing actions.

Remediation: Use unpredictable anti-CSRF tokens, validate them server-side, configure appropriate SameSite cookie controls, and require re-authentication or confirmation for highly sensitive actions.

Evidence 4 — CSRF

Crafted request resulted in a password-change response in the local DVWA lab.

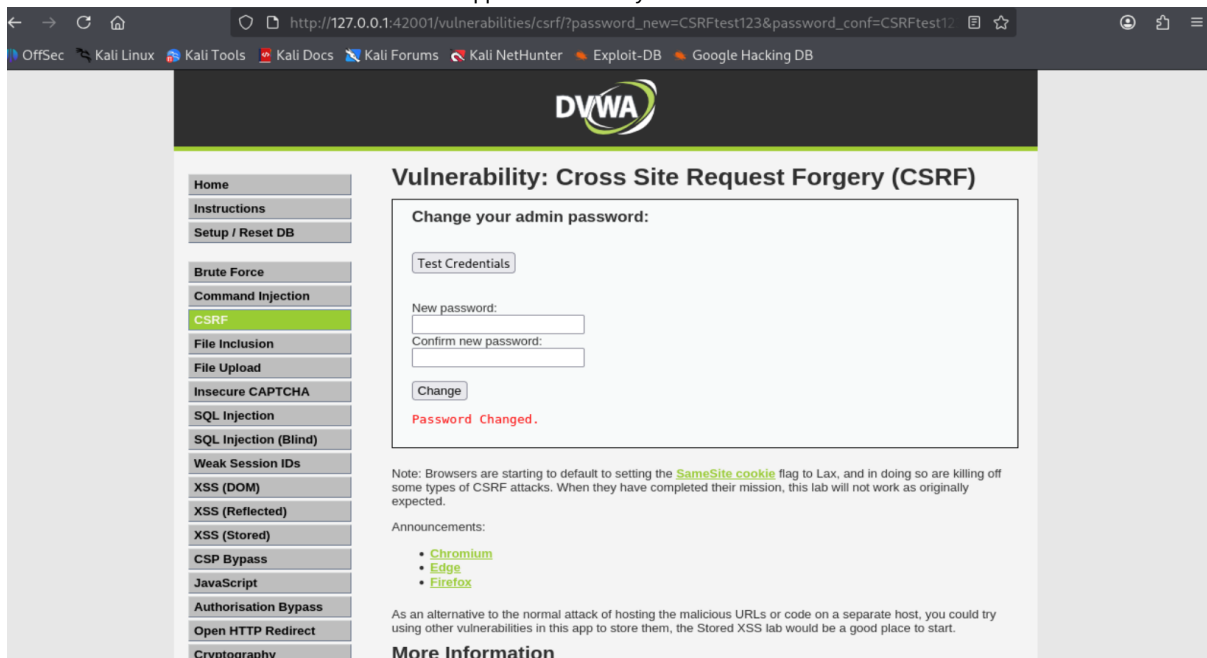


Figure: Evidence 4 — CSRF

7. Response and Security Headers Analysis

Burp Suite was used to inspect the HTTP response. The captured response contained basic headers such as Server, Content-Type, Connection, Cache-Control and Expires. Recommended defensive headers were not observed in the tested response.

- Content-Security-Policy (CSP): restricts the sources from which scripts and other resources may load.
- X-Content-Type-Options: nosniff: helps prevent MIME-type sniffing.
- Referrer-Policy: limits unnecessary referrer information disclosure.
- Strict-Transport-Security (HSTS): should be considered when the application is deployed over HTTPS.

Evidence 5 — Security Headers

Burp Suite response showing the observed HTTP response headers.

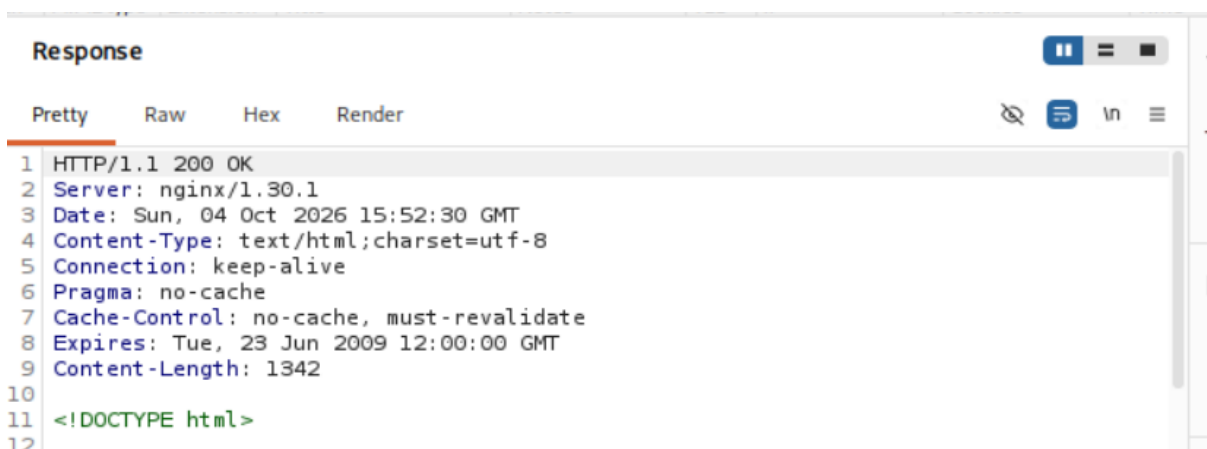


Figure: Evidence 5 — Security Headers

8. Brute Force Assessment

Authentication behavior was assessed using an invalid password and the known valid credentials of the local DVWA lab. The invalid attempt produced an authentication error, while the valid credentials successfully reached the protected area.

A Burp Intruder workflow was also prepared for password testing. Because the available Burp Community Edition environment did not complete the intended automated Intruder run, this report does not claim a successful automated brute-force attack. The manual authentication behavior nevertheless demonstrates the need for stronger defensive controls.

Remediation: Apply rate limiting, progressive delays, temporary lockout/throttling, strong password controls, monitoring/alerting and MFA for sensitive accounts.

Evidence 6 — Brute Force Failed Login

Invalid authentication attempt and failed-login response.

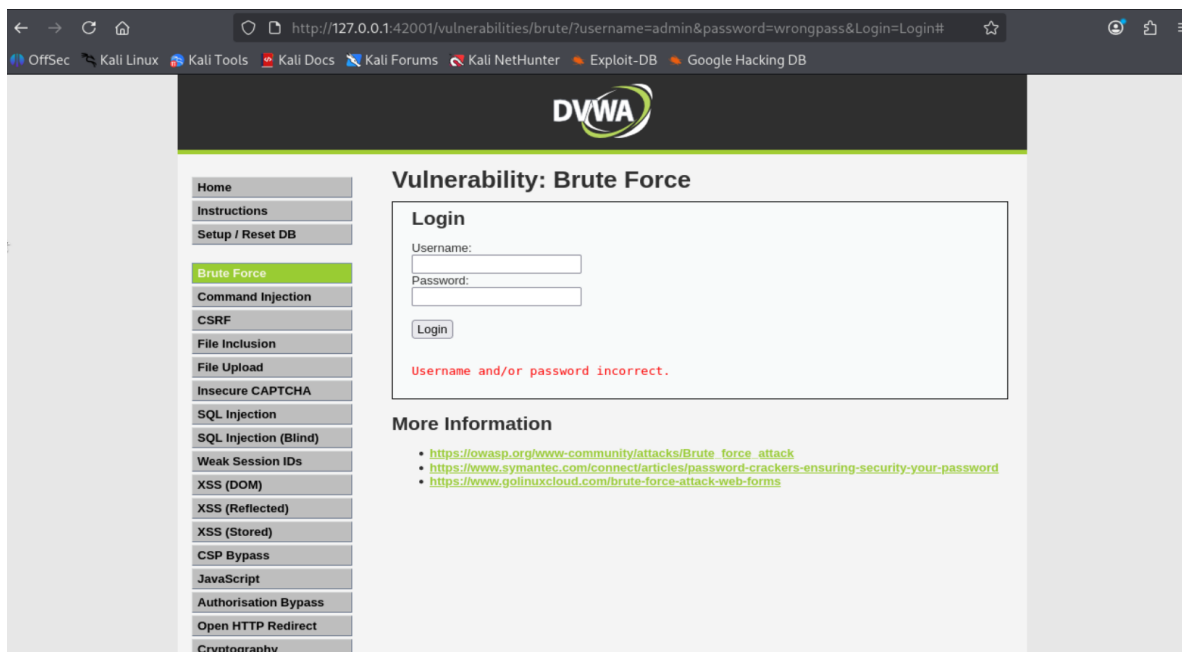


Figure: Evidence 6 — Brute Force Failed Login

Evidence 7 — Brute Force Successful Login

Known valid lab credentials successfully authenticated to the vulnerable application.

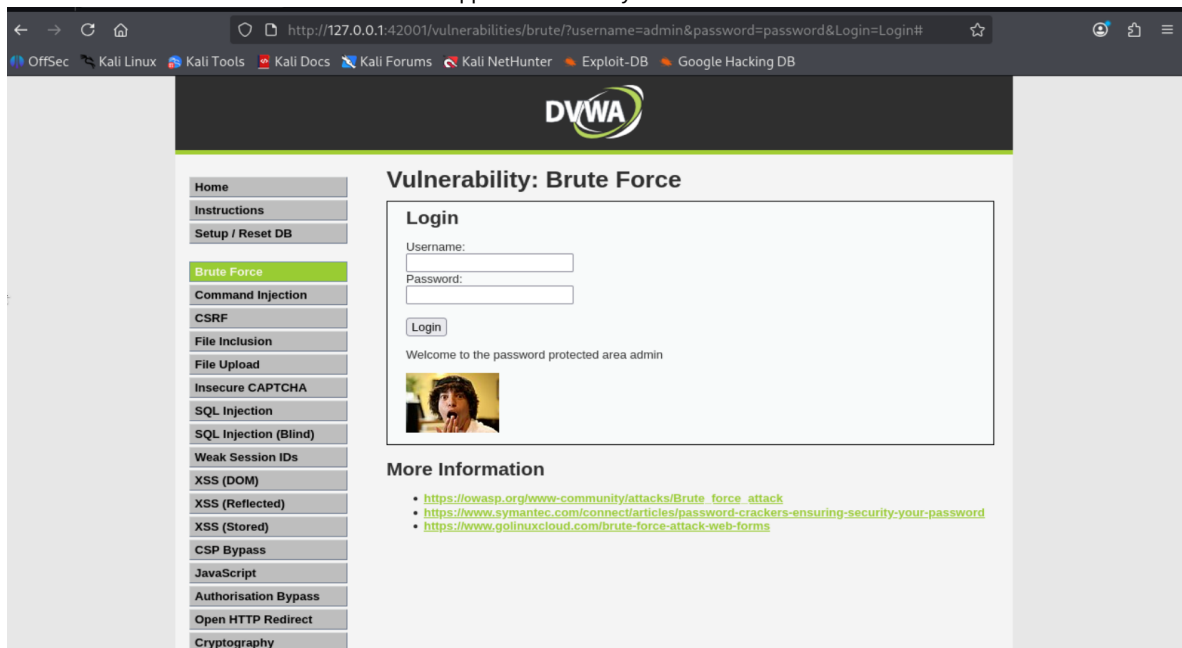


Figure: Evidence 7 — Brute Force Successful Login

9. PII Assessment

The vulnerable SQL Injection page displayed user-related information including a user ID, first name and surname. This demonstrates that an application vulnerability can lead to disclosure of information that should be protected from unauthorized access.

Legal and ethical considerations: PII should only be accessed with authorization, should be minimized to what is necessary, and should be protected from unauthorized disclosure. Security testing must remain within the authorized scope.

Remediation: Fix the underlying injection weakness, enforce server-side authorization, use parameterized queries, apply least privilege and data minimization, and protect sensitive information throughout its lifecycle.

Evidence 8 — PII Exposure

User-related information visible through the vulnerable SQL Injection page.

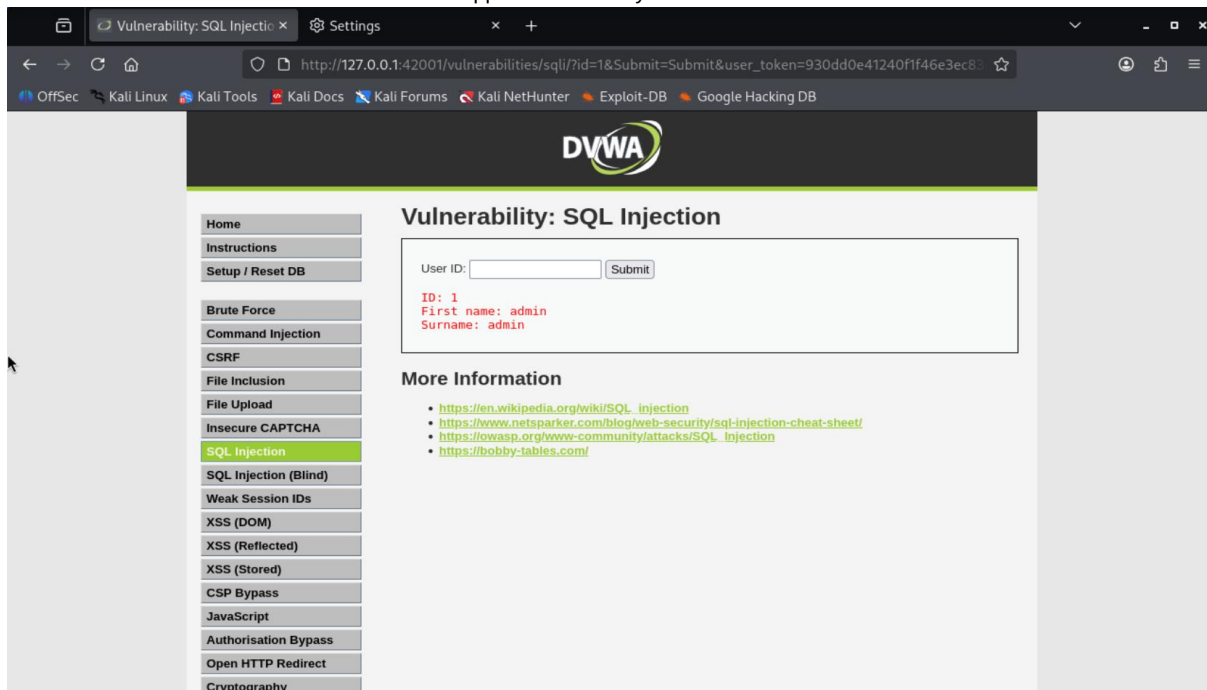


Figure: Evidence 8 — PII Exposure

10. Consolidated Remediation Plan

Finding	Priority	Recommended Action
Reflected / Stored / DOM XSS	High	Context-aware output encoding, validation/sanitization, safe DOM APIs and CSP.
CSRF	High	Anti-CSRF tokens, SameSite cookies and server-side validation.
Security headers	Medium	Deploy CSP, X-Content-Type-Options and other appropriate security headers.
Brute-force exposure	Medium	Rate limiting, throttling/lockout, monitoring and MFA.
PII exposure	High	Fix injection/access-control weaknesses and minimize/protect exposed data.

11. Security Awareness Campaign

Recommended awareness messages for developers and users:

- Never trust user-controlled input. Validate input on the server and encode output according to context.
- Use parameterized queries/prepared statements for database access.
- Protect every state-changing operation against CSRF.
- Do not expose session tokens, passwords, hashes or unnecessary PII in screenshots, repositories or reports.
- Use security headers and maintain a secure application configuration baseline.
- Use strong passwords, MFA and monitoring to reduce authentication attacks.
- Perform security testing only against systems for which explicit authorization exists.

12. Evidence Index

Evidence	File	Description
1	01_Reflected_XSS(1).png	Reflected XSS payload execution in the local DVWA application.
2	02_Stored_XSS(1).png	Stored XSS payload execution from stored guestbook content.
3	03_DOM_XSS(1).png	DOM-based XSS triggered through attacker-controlled URL input.
4	04_CSRF_Password_Change.png	Crafted request resulted in a password-change response in the local DVWA lab.
5	05_Security-Headers_Analysis.png	Burp Suite response showing the observed HTTP response headers.
6	06_BruteForce_Failed_Login.png	Invalid authentication attempt and failed-login response.
7	07_BruteForce_Success.png	Known valid lab credentials successfully authenticated to the vulnerable application.
8	08_PII_Exposure.png	User-related information visible through the vulnerable SQL Injection page.

13. Conclusion

The controlled DVWA assessment successfully demonstrated reflected, stored and DOM-based XSS, CSRF exposure, weak/missing recommended security headers, authentication weaknesses relevant to brute-force protection, and PII exposure. The findings show the importance of secure input handling, context-aware output encoding, anti-CSRF controls, security headers, strong authentication protections, authorization, and responsible handling of personal information.

All testing documented in this report was performed against the intentionally vulnerable local DVWA environment for authorized educational purposes.